

Zero Trust Architecture

組員:

41343109 吳育丞

41343124 張豈瑞

大綱

- 介紹
- 零信任基礎
- 零信任架構的邏輯元件
- 部署情境與使用案例
- 與零信任架構相關的威脅
- 參考文獻

介紹

- **Zero Trust (ZT, 零信任) :**

零信任主要著重在：

資料 (Data) 與服務 (Services) 的保護但它的適用範圍應該進一步擴大到 組織 中的所有資產，例如：裝置、基礎設施元件、應用程式、虛擬與雲端元件。

同時也包括各種「Subject」。只要某個實體會向資產 要求資訊，就可以被視為 Subject。

- **Zero Trust Architecture (ZTA, 零信任架構)** 它主要被設計來：

防止資料外洩 (Data Breach) 並：限制企業網路內的橫向移動 (Internal Lateral Movement)。

介紹

- 最小權限與持續驗證

在 Zero Trust 中，系統必須持續地：

Authentication（驗證身分）, Authorization（確認是否有權限）確認每一次 Access Request 的身分（Identity）, 安全狀態（Security Posture）。

並不是：



fig.1

而是：

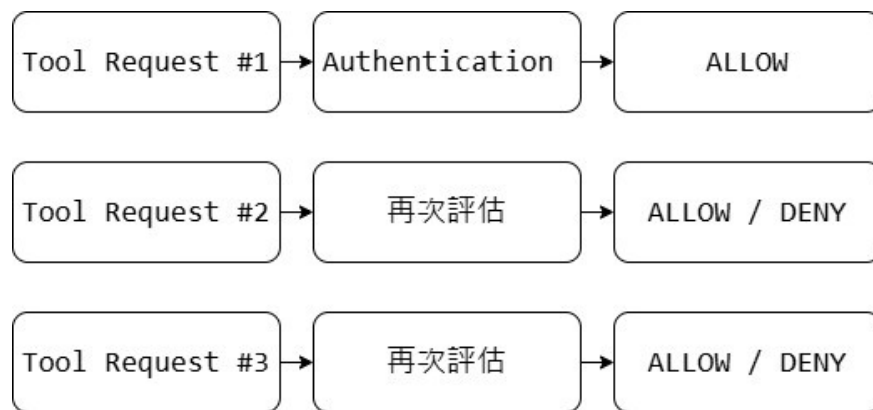


fig.2

零信任基礎

- **Zero Trust 定義**

Zero Trust Architecture 是一種：

End-to-End（端到端）的企業資產與資料安全方法。

- **Principle of Least Privilege(最小權限)**

- **NIST 對 Zero Trust 的操作性定義**

Per-request Access Decision：

Request 1

→ Evaluate

→ ALLOW / DENY

Request 2

→ Evaluate

→ ALLOW / DENY

Request 3

→ Evaluate

→ ALLOW / DENY

Identity	身分
Credentials	憑證
AccessManagement	存取控制
Operations	操作
Hosting Environment	託管環境
Infrastructure	基礎設施
Endpoints	端點

零信任基礎

所有請求預設不可信：使用者即使已登入，也不能代表後續所有資源請求都可信。

PDP / PEP 是安全關卡：負責驗證身分、判斷請求是否合法，並決定是否允許存取。

縮小隱含信任區域：PDP / PEP 盡可能靠近受保護資源，避免通過一次檢查後就能自由存取其他資源。



Fig. 3: Zero Trust Access

零信任基礎-零信任的核心原則

- 原則 1：所有資料來源與運算服務都應被視為資源
- 原則 2：無論網路位置在哪裡，所有通訊都必須受到保護
- 原則 3：對單一資源的存取應以個別 Session 為基礎授予
- 原則 4：資源存取必須由 Dynamic Policy 決定
- 原則 5：組織必須持續監控並衡量資產的完整性與安全狀態
- 原則 6：所有資源的驗證與授權都必須是動態的，而且必須在允許存取之前嚴格執行
- 原則 7：收集目前環境的資訊，並利用這些資訊持續改善安全狀態

零信任基礎-從零信任角度看網路

1. 整個組織私有網路都不應被視為「隱含信任區域（**Implicit Trust Zone**）」
2. 網路上的裝置不一定屬於組織，也不一定能由組織直接管理
3. 沒有任何 **Resource** 天生可信
4. 並非所有企業資源都位於企業自己的基礎設施內。
5. 遠端 **Subject** 與 **Asset** 不能完全信任目前所使用的本地網路。
6. 資產與工作流程在組織內、外部基礎設施之間移動時，應保持一致的安全政策與 **Security Posture**。

零信任架構的邏輯元件

1. Policy Engine (PE, 政策引擎)
2. Policy Administrator (PA, 政策管理器)
3. Policy Enforcement Point (PEP, 政策執行點)

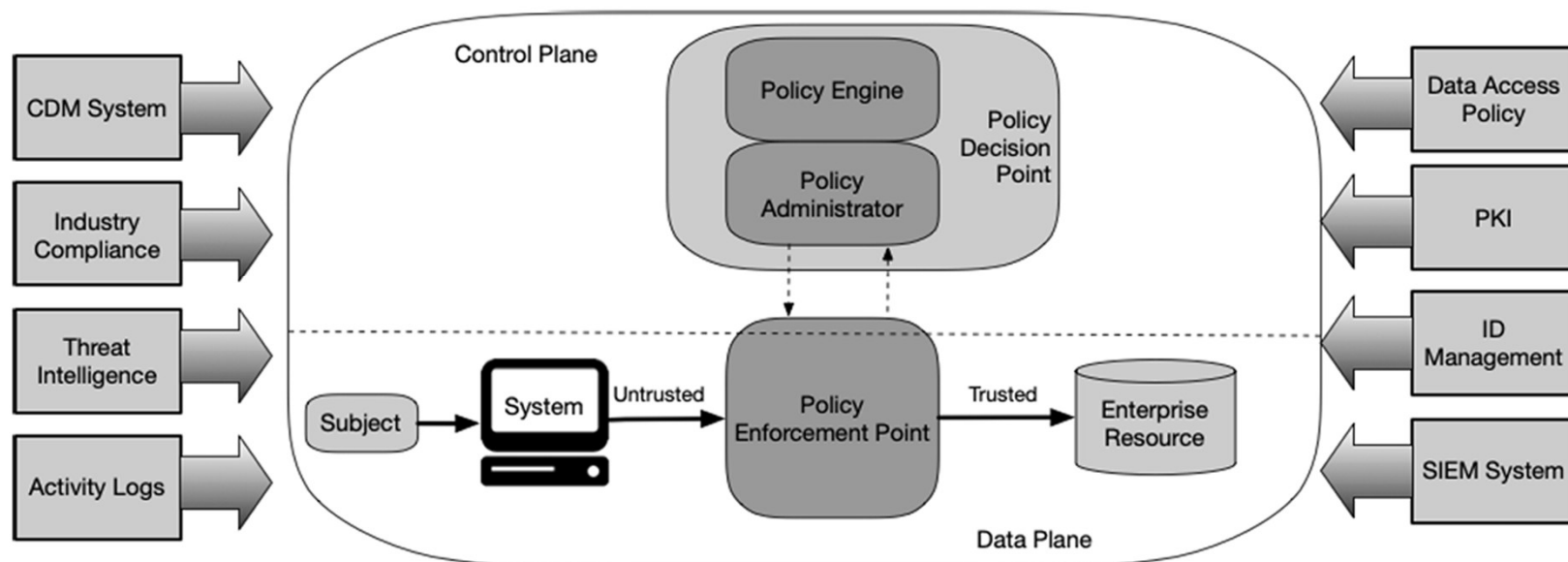


Fig. 4: Core Zero Trust Logical Components

零信任架構的邏輯元件

1. 持續診斷與緩解系統（Continuous Diagnostics and Mitigation，CDM）
2. 產業法規遵循系統（Industry Compliance System）
3. 威脅情報來源（Threat Intelligence Feeds）
4. 網路與系統活動日誌（Network and System Activity Logs）
5. 資料存取政策（Data Access Policies）
6. 企業公開金鑰基礎設施（Enterprise Public Key Infrastructure，PKI）
7. 身分管理系統（ID Management System）
8. 安全資訊與事件管理系統（Security Information and Event Management，SIEM）

零信任架構的邏輯元件-零信任架構方法的不同類型

企業可以透過多種方式，將零信任架構應用於工作流程。

不同方法在使用的元件，以及組織政策規則的主要來源方面有所差異。

完整的零信任解決方案通常會結合以下三種方法的部分元素：

- 以強化身分治理為核心的方法。
- 邏輯微分段方法。
- 以網路基礎設施為基礎的分段方法。

企業在規劃零信任架構時，可以根據預定的使用情境及現有政策，判斷哪一種方法較容易導入。這並不代表其他方法不可行，而是其他方法可能更難實施，或需要對企業現有的業務流程進行更根本的調整。

零信任架構的邏輯元件-零信任架構方法的不同類型

1. 使用強化身分治理的零信任架構（ ZTA Using Enhanced Identity Governance ）
2. 使用微分段的零信任架構（ ZTA Using Micro-Segmentation ）
3. 使用網路基礎設施與軟體定義邊界的零信任架構
（ ZTA Using Network Infrastructure and Software Defined Perimeters ）

零信任架構的邏輯元件-抽象架構的實際部署變化

1.裝置代理程式／閘道部署（Device Agent/Gateway-Based Deployment）

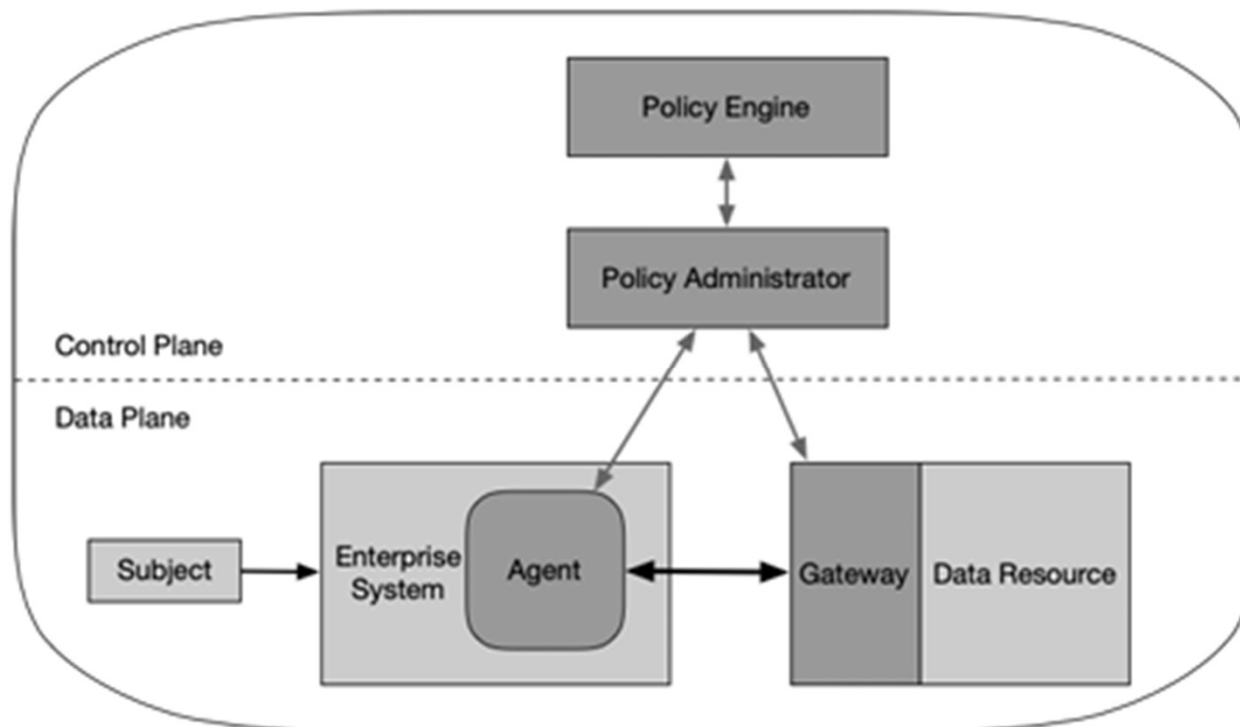


Fig. 5: Device Agent/Gateway Model

零信任架構的邏輯元件-抽象架構的實際部署變化

2.基於安全飛地的部署 (區域式閘道部署) (Enclave-Based Deployment)

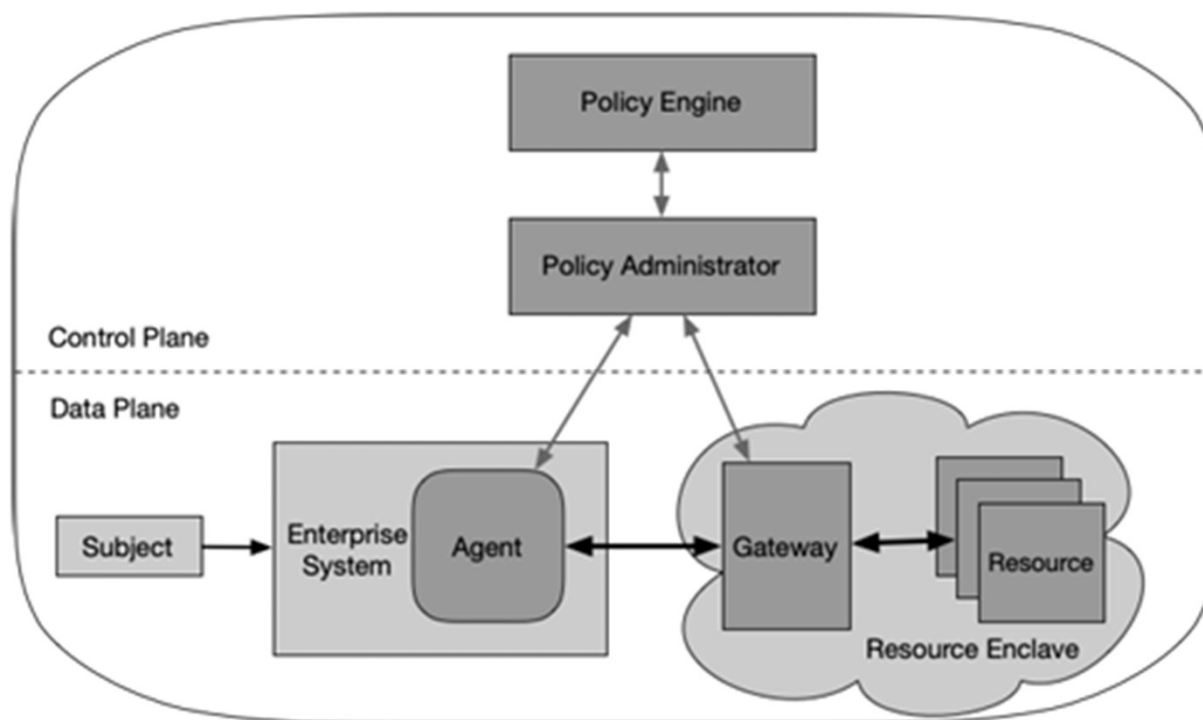


Fig. 6: Enclave Gateway Model

零信任架構的邏輯元件-抽象架構的實際部署變化

3.資源入口網站部署（Resource Portal-Based Deployment）

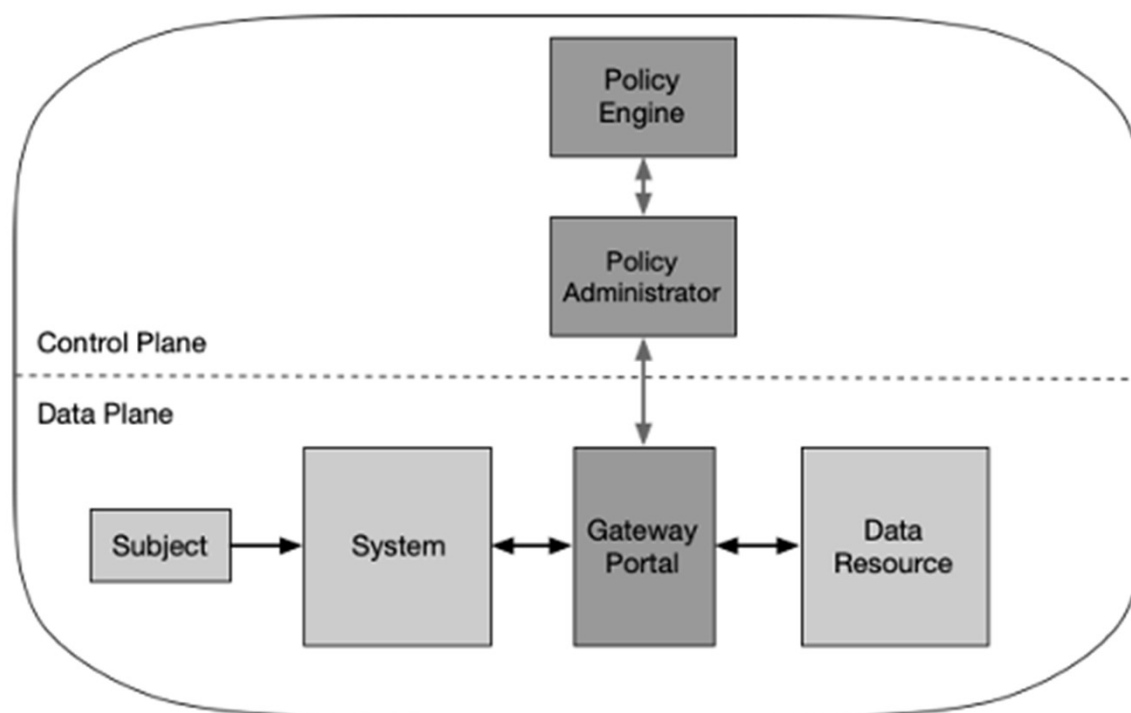


Fig. 7: Resource Portal Model

零信任架構的邏輯元件-抽象架構的實際部署變化

4.裝置應用程式沙箱化（Device Application Sandboxing）

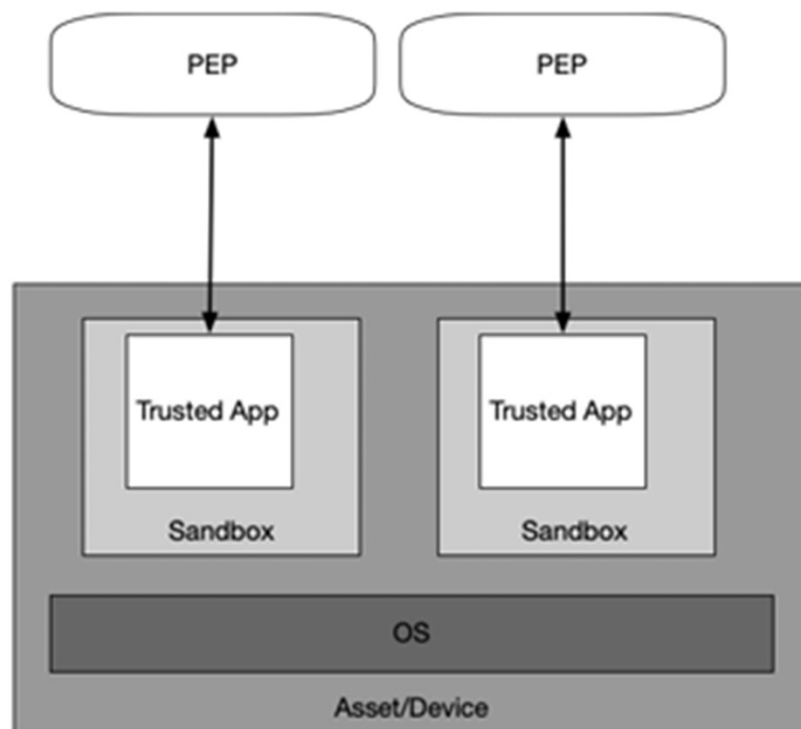


Fig. 7: Application Sandboxes

零信任架構的邏輯元件-信任演算法

信任演算法的輸入資料

1. 存取請求 (Access Request)
2. 主體資料庫 (Subject Database)
3. 資產資料庫與可觀察狀態
(Asset Database and Observable Status)
4. 資源需求 (Resource Requirements)
5. 威脅情報 (Threat Intelligence)

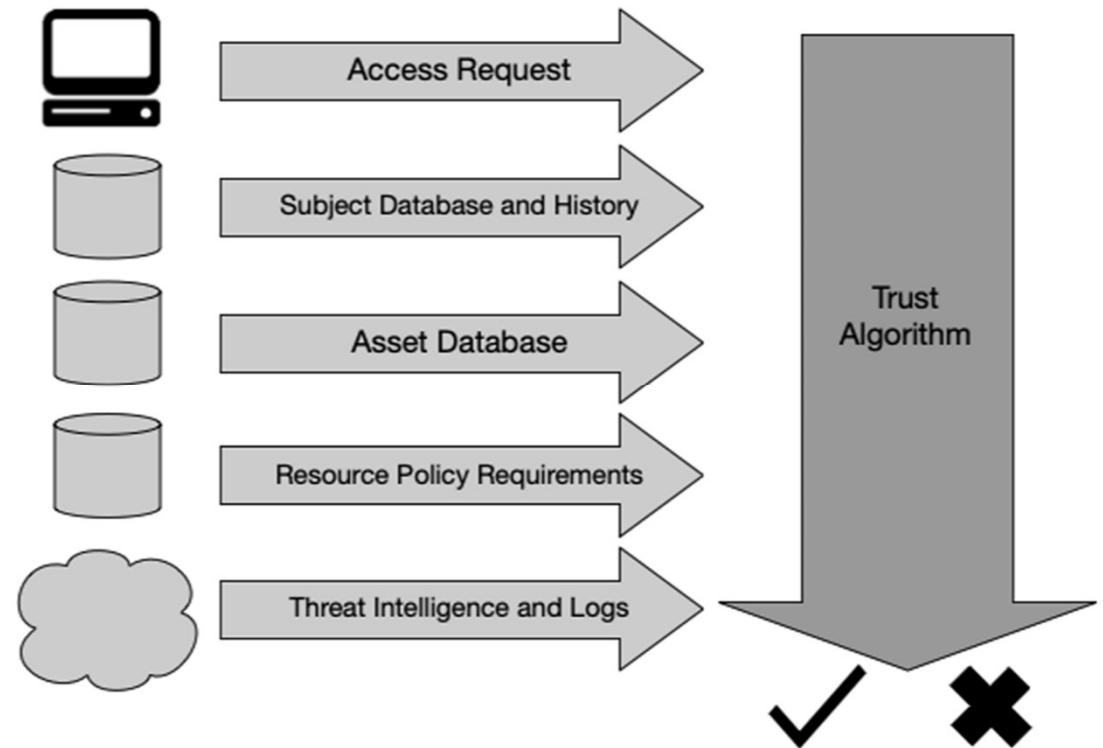


Fig. 8: Trust Algorithm Input

零信任架構的邏輯元件-信任演算法

1. 信任演算法的不同形式（Trust Algorithm Variations）
 - 一. 條件式與分數式（Criteria-Based versus Score-Based）
 - 二. 單次獨立評估與情境式評估（Singular versus Contextual）

分類方式	第一種	第二種
如何判斷信任程度	條件式：檢查是否符合條件	分數式：計算信任分數
是否參考過去行為？	單次獨立評估：只看這次請求	情境式評估：參考歷史行為

零信任架構的邏輯元件-網路與環境元件

1. 支援零信任架構的網路需求（Network Requirements to Support ZTA）
 - 一. 企業資產必須具備基本網路連線能力。
 - 二. 企業必須能夠區分自有或受管理的資產，並掌握裝置目前的安全狀態。
 - 三. 企業必須能夠觀察所有網路流量。
 - 四. 未經政策執行點的存取控制，企業資源不應能被直接連線。
 - 五. 資料平面與控制平面在邏輯上必須分離。
 - 六. 企業資產必須能夠連線到政策執行點。
 - 七. 在業務流程中，只有政策執行點會存取政策管理者。
 - 八. 遠端企業資產應能夠直接存取企業資源，而不必先經過企業網路基礎設施。
 - 九. 支援零信任存取決策的基礎設施，必須具備可擴充性。
 - 十. 企業資產可能因政策或可觀察到的因素，而無法連線到特定政策執行點。

部署情境與使用案例

任何企業環境都可以按照 **Zero Trust**（零信任）的核心原則來進行設計。事實上，大多數組織的企業基礎設施中，可能已經包含某些 **Zero Trust** 元素，或者正透過資訊安全、韌性政策以及最佳實務的導入，逐步朝這個方向發展。有一些部署情境與使用案例特別適合採用 **Zero Trust Architecture**（ZTA）。

在下面的使用案例中，圖中不一定會明確標示哪些部分「就是 **ZTA**」，因為在真實企業中，很可能同時存在：

傳統 **Perimeter-Based Infrastructure**（邊界式網路架構）

以及 **Zero Trust Architecture** 元件 兩者並存。

部署情境與使用案例-具有分支/遠端據點的企業

1. 遠端據點不一定具有完整企業網路
2. 遠端工作者
3. PE / PA 可以部署在 Cloud
4. 為什麼不一定把 PE / PA 放在總部？

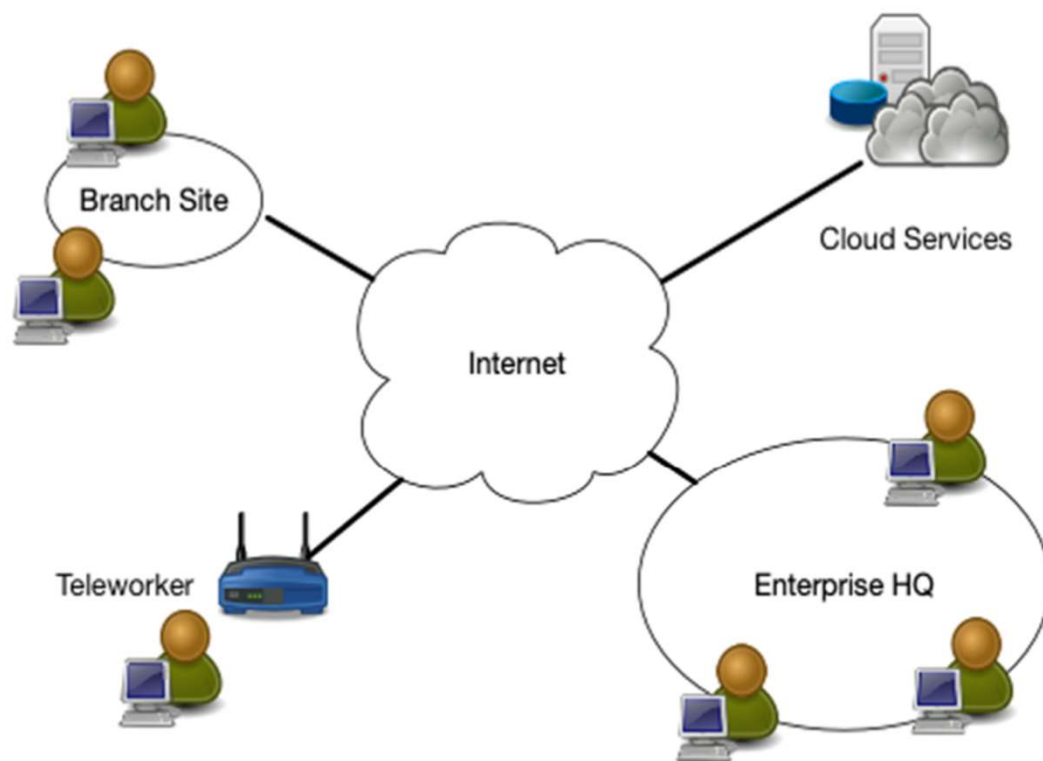


Fig. 9: Enterprise with Remote Employees

部署情境與使用案例-多雲端/雲端對雲端企業

1. Multiple Cloud Providers (多個雲端服務供應商)

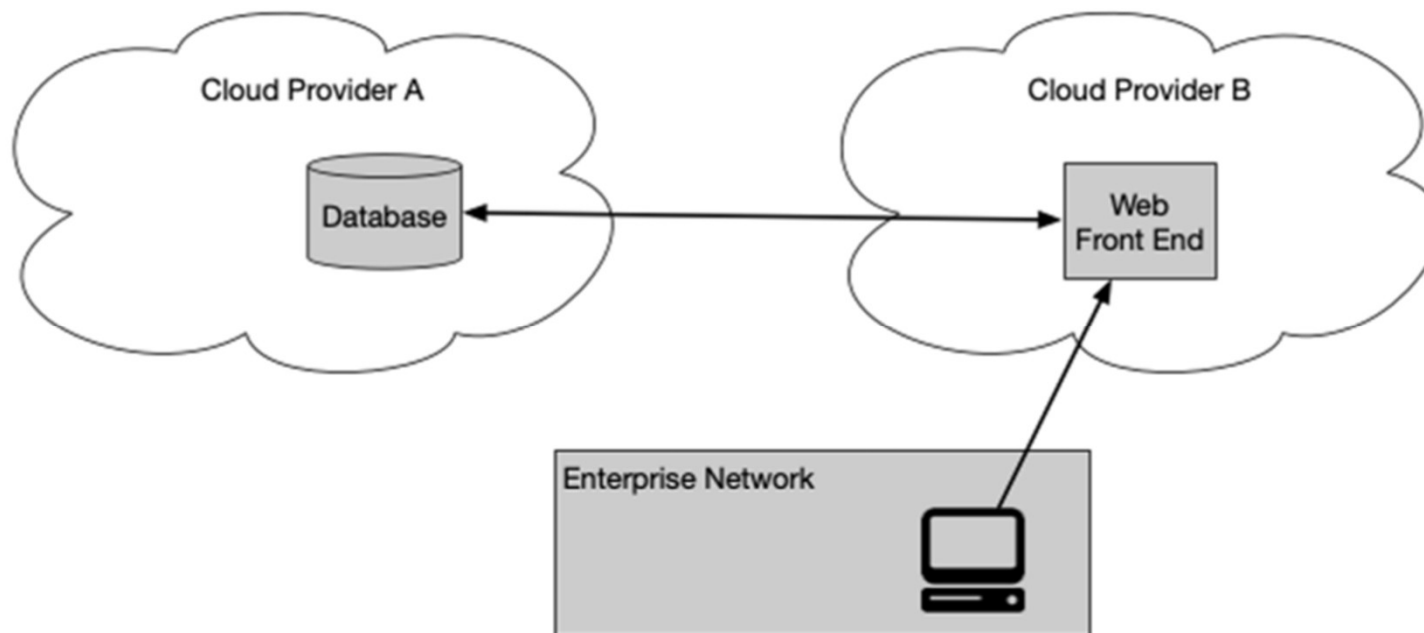


Fig. 10: Multi-cloud Use Case

部署情境與使用案例-具有外包服務及/或非員工存取需求的企業

1. 企業中同時存在員工、外包人員與訪客
2. 非員工進入企業環境，
不代表具有內部資源存取權
3. 員工依身分與權限存取內部系統
4. 外包人員僅能存取工作所需資源
5. 訪客通常只允許使用 **Internet**
6. 核心原則：不因位於企業內網就自動信任

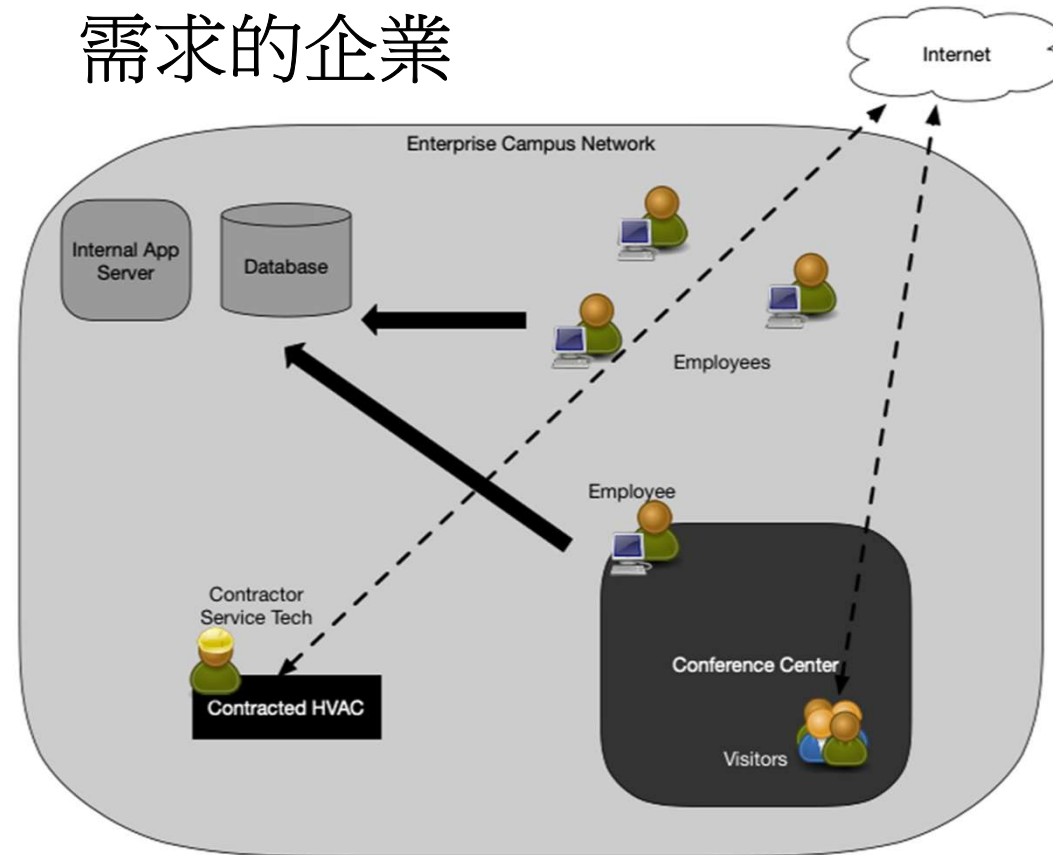


Fig. 11: Enterprise with Nonemployee Access

部署情境與使用案例-跨企業邊界協作

1. Enterprise A 與 Enterprise B 進行跨組織合作
2. Enterprise B 的使用者可存取 Enterprise A 的特定資源
3. 例如允許存取 DB1，但不代表可以存取 DB2
4. 可透過 Federated Identity 驗證跨組織使用者身分
5. 存取權仍由資源擁有者的 Policy 決定，遵循最小權限原則

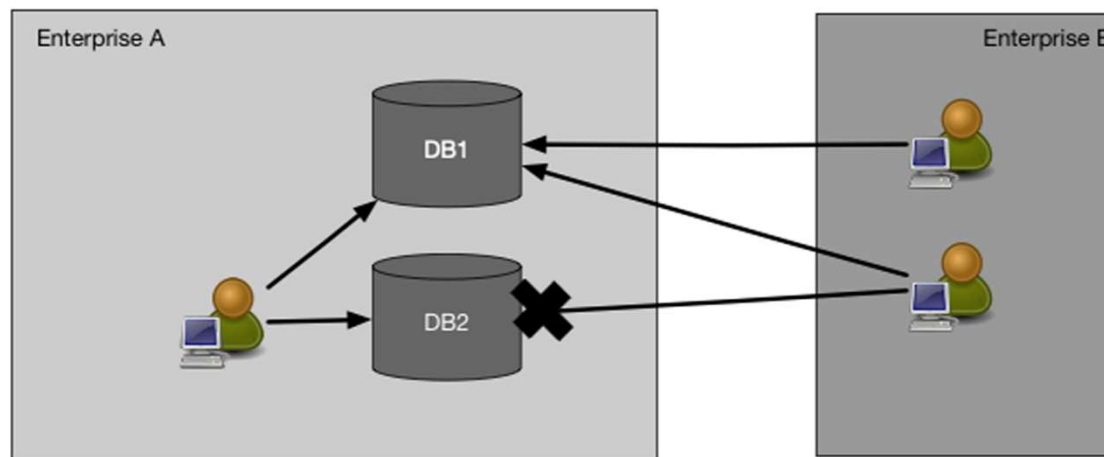


Fig. 12: Cross-Enterprise Collaboration

部署情境與使用案例-具有公開或 面向客戶服務的企業

- 1.外部使用者與裝置不可預設可信
- 2.區分匿名服務與需登入服務
- 3.透過 Identity、MFA 強化已註冊使用者驗證
- 4.分析 Browser、Request Rate、行為異常偵測攻擊
- 5.動態限制存取，同時兼顧隱私與法規

與零信任架構相關的威脅

1. 零信任架構決策流程遭到操縱
2. 阻斷服務攻擊或網路中斷
3. 憑證遭竊與內部人員威脅
4. 網路可視性
5. 系統與網路資訊的儲存
6. 對專有資料格式或解決方案的依賴
7. 零信任管理中非人類實體的使用

參考文獻

[1] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, Zero Trust Architecture, NIST Special Publication 800-207, National Institute of Standards and Technology, Aug. 2020, doi: 10.6028/NIST.SP.800-207.